

Pricing Deception: When a Web-Attack Detector Should Probe Rather Than Decide

Parth Kansal, Amrit Singh Nijjar, and Siddhant Mehta

Department of AIT-CSE, Chandigarh University,
Gharuan, Mohali, Punjab, India

parth.kansal823@gmail.com, amrit.nijjar814@gmail.com, 23bis70162@cuchd.in

Abstract. A web application firewall must commit, allow or block, on the evidence one request carries. Deception normally happens after that commitment: a session already judged hostile is moved into a honeypot. We treat it instead as a move available while the detector is still unsure. When intent is uncertain the defence adds an invisible, inert probe to the response, such as a fake table named in an error. An honest client never renders it; someone probing the application acts on it, and reveals intent. Our contribution is the rule deciding when to deploy one. A probe brings no immediate benefit, since the request still reaches the real application, so its whole worth is the information a bite reveals. Priced as the expected value of that information, probing becomes cost-optimal over a belief band whose edges follow from a frozen cost table and a measured bite likelihood ratio. Under cost accounting alone the band is empty, so there is no middle action to tune. Over 99 seeded traffic draws against one frozen model, a randomised holdout puts the probe’s causal effect at $+0.070$ $[+0.052, +0.088]$ (Fisher exact, $p = 3.4 \times 10^{-19}$), and recall rises from 0.889 to 0.943 (paired McNemar, $p = 1.9 \times 10^{-95}$), concentrated in the one attack category the passive detector cannot settle. No legitimate session was diverted, including the four the passive baseline lost.

Keywords: cyber deception · value of information · cost-sensitive detection · web application security · honeytokens.

1 Introduction

A web application firewall makes a binary choice on every request: let it through or block it, on what that request alone reveals. The trade-off is familiar. Act early on thin evidence and legitimate users get blocked; wait for evidence strong enough to be safe and the attacker has had several requests’ head start. Learned detectors soften the edges but do not escape it. They still watch, wait, and commit on one accumulated score.

Deception is the usual answer to passivity, yet in almost every deployment it comes *after* the decision: a request is judged hostile, and only then is the session moved into a honeypot. Deception is a consequence of detection, not an instrument of it. We have not found prior work treating it as a move available while the detector is still unsure.

That move is the subject of this paper. When the system is uncertain, it adds something to the response that a browser never renders but anyone reading raw bytes will see: a fake database error, an unused JSON field, a hint at a deprecated endpoint. An honest user notices nothing; someone probing the application acts on it, and reveals what a passive score could only wait for. We call these probes *bait*. Our question is not how to build them, since invisibility and consistency are engineering, but when to deploy one at all.

That decision need not be a heuristic. A probe brings no immediate benefit, since the request it rides on still reaches the real application, so baiting an attacker costs what letting one through costs. Its whole value is the information a bite reveals, and that value can be computed. Priced as the expected value of the sample information it buys, a probe becomes the cost-optimal action over a belief band *derived* from the cost of the defender’s errors and the *measured* effectiveness of the probe. Account for the same costs without the information term and the band vanishes: there is nothing there to tune.

Contributions. The ingredients are old. New here is the rule deciding *when* to deceive, and that its parameters are derived rather than chosen.

1. **A priced third action** (Section 3.2). Probing maximises the expected value of sample information over a band whose edges come out of a frozen cost table and calibrated probe effectiveness. Under cost accounting alone that band is empty, so the middle action is priced rather than tuned.
2. **Bait as a randomised treatment** (Section 4). A fixed fraction of sessions reaching the band are deliberately left unbaited. Assignment is random at the same belief state, so the gap between the arms estimates the *causal* effect of baiting instead of comparing two systems.
3. **Consistency across the divert boundary** (Section 3.4). A decoy can be perfectly self-consistent while contradicting everything the attacker saw before being moved. We show that self-consistency is the wrong estimand, and measure the right one.

We test against off-the-shelf attack tools we did not write and against the OWASP ModSecurity Core Rule Set on identical traffic, and we report where the approach does not win (Section 5).

2 Literature Review

Every ingredient here is established. What is new is where the decision to deceive sits and how its parameters are set.

Detection is passive, and blind where syntax is valid. Signature firewalls match known-bad patterns and are blind to attacks that are valid syntax. Learned detectors trade brittleness for a model, from early anomaly-based detectors of web requests [12] to recent adaptive approaches [1]. All share the passive stance: watch a session accumulate evidence, then commit on a score. Our detector is

one of these and is not the contribution; a signature firewall and the passive meter are our baselines because the contribution sits on top of them. A separate line asks whether a client is a script rather than whether it is hostile [8], and its most useful finding for us is negative: advanced bots imitate browser fingerprints closely enough that automation signals alone stop separating them from people.

Deception is a destination, not an instrument. Deception as defence is well studied, from virtual honeypot frameworks [15] through game-theoretic treatments [13] to whether decoys actually change attacker behaviour [6]. In almost all of it deception is a *destination*: a caught attacker is moved somewhere, after a decision already taken. Planting a credential as a tripwire is likewise old and widely deployed [20, 9], but that literature treats honeytokens as always-on. Recent application-layer work automates their deployment, rotation and teardown properly [11, 10] and stops where we begin: it does not decide *when* to deploy one from a belief about the visitor being served.

Generated decoys are measured for fidelity, not contradiction. Language models increasingly generate convincing interactive honeypots [16, 4]. That line is complementary rather than competing, since our consistency layer is generator-agnostic and a language model is exactly what it is built to sit in front of. What it lacks is the guarantee: evaluation frameworks measure stealth and fidelity [18], not whether a decoy contradicts itself over an engagement — and they measure it *within* the decoy, which Section 3.4 argues is the wrong estimand for a decoy an attacker is moved into.

Cost-sensitive detection has no information-purchase action. Our machinery is decades old: the expected value of sample information [7], cost-sensitive decisions under a loss matrix [5], signalling models of deception with evidence [14], and the base-rate constraints binding any intrusion detector [3]. None offers an action that buys evidence, so none can express *probe in order to find out* — the gap Section 3.2 fills. Throughout we follow the methodological cautions of [17, 2].

3 Methodology

3.1 System and Threat Model

We consider an attacker whose intent cannot be settled from any single request. Some requests carry obfuscated payloads that a signature written for the canonical form misses [1]; others carry no payload at all. The clearest case, and the one we lean on throughout, is an insecure direct object reference: `/records/5` is syntactically indistinguishable from `/records/6`, yet if the second object is not yours the request is an attack and nothing in its bytes says so. There is no signature to write, and a behavioural detector struggles because a benign integration reading its own records in order produces the same shape. This is where a passive score is genuinely uncertain.

Attackers vary on two independent axes, automation and intent. A scanner is automated and hostile, a price-comparison bot automated and harmless, a careful human manual and hostile. Modern bots imitate browser fingerprints well enough that automation signals alone stop separating them from people [8], so collapsing both axes onto one score cannot tell the second case from the third. Half of our simulated attack sessions therefore drive a real browser and fetch page sub-resources, since much current tooling is built on Selenium or Playwright and inherits that whatever the operator intends. Out of scope are network-layer attacks, denial of service, and client-side attacks on other users. We assume the attacker has not previously mapped the decoy world; honeypots have been fingerprinted at scale [19].

The defender runs a reverse proxy in front of the real application, which never sees an unfiltered request nor knows the deception machinery exists. Every request follows the same path: identify the session by cookie, with a fingerprint fallback for clients that drop them; reduce it to eighteen features computed only from what a live proxy can observe; update a two-part suspicion score; price the three actions and take the cheapest; write the decision to an append-only, hash-chained log.

The features split along the two axes. Ten *automation* features describe how the client behaves: inter-request timing and its regularity, whether static assets are fetched, browser-header completeness, whether a cookie is carried. Eight *malice* features describe what it is trying to do: special-character density in client-controlled input, database keywords in syntactic context, error-response ratio, failed authentications, and how many distinct accounts it has tried to log in as. Two logistic heads, one per axis, accumulate across the session. Separating them earns its keep twice: cost depends on hostility alone, so the belief driving the policy is the malice score, while the automation score is spent on choosing *which* probe to deploy, because a scanner and a careful human take different bait at different rates.

3.2 Pricing the Probe as an Information Purchase

At each point in a session the defender holds a belief $p \in [0, 1]$ that the client is hostile, and chooses one of three actions. *Pass* forwards the request to the real application. *Divert* moves the session into the decoy. *Bait* injects an invisible, inert probe into the response and forwards the request unchanged. Each (action, true-class) pair carries a cost fixed in Table 1, which is hashed and frozen before any data is collected, so no threshold derived below can have been tuned to the results.

Three entries carry the argument. Diverting a benign user must almost never happen, so it is priced two orders of magnitude above any other error. Baiting a hostile client costs exactly what passing one costs, because the request still reaches the real application, so the only difference between passing and baiting is the small nuisance cost borne by the benign probability mass. Taking expectations under p , each action’s immediate expected cost is affine:

$$\mathbb{E}[C_{\text{pass}}] = 25p, \quad \mathbb{E}[C_{\text{bait}}] = 1 + 24p, \quad \mathbb{E}[C_{\text{divert}}] = 200 - 220p. \quad (1)$$

Under cost accounting alone there is no third action. Comparing the first two, $\mathbb{E}[C_{\text{bait}}] - \mathbb{E}[C_{\text{pass}}] = 1 - p \geq 0$ for every belief: baiting is *strictly* more expensive than passing everywhere, by exactly the residual benign-nuisance term. The middle action is therefore never chosen, and the policy collapses to a two-way rule with a single crossover at $25p = 200 - 220p$, i.e. $p^* = 200/245 \approx 0.816$ — one PASS/DIVERT boundary and **no band anywhere in between**. This is the sharpest answer to the natural objection that the middle action is a tuned threshold: *there is no middle action to tune*. It appears only once the information a probe buys is priced.

Pricing the probe. A probe’s worth is entirely informational: it yields an observation $Z \in \{\text{bite}, \text{no-bite}\}$ that sharpens the belief and therefore the next decision. We price it by the expected value of sample information (EVSI) [7]:

$$V(p) = \min_a \mathbb{E}[C(a) \mid p] - \mathbb{E}_Z \left[\min_a \mathbb{E}[C(a) \mid p'(Z)] \right], \quad (2)$$

where $\beta_a = P(\text{bite} \mid \text{hostile})$ and $\beta_b = P(\text{bite} \mid \text{benign})$ are the calibrated rates of Section 3.3, $P(\text{bite} \mid p) = p\beta_a + (1-p)\beta_b$, and the posteriors follow by Bayes’ rule. Both inner minima are over the same three affine lines, so V evaluates in closed form at any belief and nothing requires simulation. The rule prices bait at its immediate cost *net of* the information it buys: $\text{eff}(\text{bait}) = 1 + 24p - V(p)$.

We claim no new mathematics. EVSI is textbook and the properties below are elementary. The contribution is the application: a response-side probe *is* a sample-information purchase, and pricing it as one turns the middle option from a heuristic into a derived action.

The band is bounded on both sides by construction. $\min_a \mathbb{E}[C(a) \mid p]$ is a minimum of affine functions and hence concave, so Jensen’s inequality gives $V(p) \geq 0$: information never hurts. And $V(0) = V(1) = 0$, since at certainty no observation can change the decision. The band therefore cannot swallow the probability range or be widened by tuning; its edges are pinned by the cost geometry. Both are enforced as runtime invariants rather than argued informally.

Bait is chosen where $V(p) > 1 - p$ and the belief is still below the divert line. With the frozen table and the calibrated library, taking the most informative probe applicable to the response in hand, the derived bands are

$$\text{PASS } p < 0.0647, \quad \text{BAIT } 0.0647 \leq p < 0.8793, \quad \text{DIVERT } p \geq 0.8793. \quad (3)$$

The two edges are set by two different probes, which is what taking a maximum over the library means. Note the direction of the upper edge: offering a probe *raises* the divert threshold from 0.816 to 0.879, so a system that can probe is more reluctant to divert an honest user than the same system without one. That falls out of the arithmetic; it was not a design goal.

One term the textbook derivation does not imply. EVSI prices a probe as though its outcome were fresh information, true the first time and false the tenth. Valuing every exposure at full price lets a bait-aware attacker who never bites be

Table 1. The frozen cost matrix. Hashed before any data was collected, so no threshold in the derivation can have been tuned to the results.

	pass bait divert		
client benign	0	1	200
client hostile	25	25	-20

baited indefinitely rather than diverted, caught by the passive baseline and not by the full system. Decaying the value geometrically in the number of unrewarded showings, $(1 - \beta_a)^k$, restores the guarantee: as the probe stops answering, the rule falls back to the two-action policy.

The conclusions survive both estimated inputs. Sweeping β_a across $[0.05, 0.99]$, and the cost table’s one judgement across $0.5\times$ to $128\times$ its frozen value, the band is non-empty at every point and the divert threshold never falls below the cost-only boundary. What moves is *where* the boundaries sit, never *whether* the third action exists, nor whether a probe could make the system divert earlier than cost accounting alone (it cannot). The frozen table is a choice about conservatism, not one that manufactures the result.

3.3 Calibrating the Probe

The rule needs one empirical input: how much a bite tells you. Set it by hand to make the system work and the derived band is a fiction dressed as a derivation. The evidence a bite carries is a likelihood ratio β_a/β_b , applied in log-odds so the update is a single addition. A bite moves the malice score sharply up; a declined probe nudges it gently down. That second ratio matters as much as the first, because a system that only revises suspicion upward will eventually divert someone for browsing slowly. For the probe carrying most of our results, 138 of 183 hostile sessions shown it took it and **0 of 74 benign ones did**, giving $\beta_a = 0.753$ and $\beta_b = 0.0067$: a bite worth $+4.7$ in log-odds, a refusal -1.4 .

These rates have no legitimate source in the obvious data. The training corpus predates the bait library and contains no bites, and the held-out corpus is the test set [2]. We therefore add a dedicated *calibration* round, run after the baits exist and frozen before evaluation, whose only permitted use is estimating probe effectiveness; the round vocabulary is enforced in the record schema so one round cannot quietly become another. The benign rate is measured rather than assumed. Setting $\beta_b = 0$ is tempting, since bait is invisible to a real browser, but it makes the ratio infinite and assumes away the safety property we exist to measure. Every benign count is in fact zero, so rates are posterior means under a Jeffreys prior, capping the ratio near 112 rather than claiming a certainty seventy-four sessions cannot support.

Four of the five deployed baits are measured (β_a from 0.563 to 0.794); one keeps a prior, is flagged as such, and is almost never selected here. A sixth was *withdrawn*: the target authenticates over HTML, so it reached zero sessions while

its β_a remained a number we invented before any data existed, and an unmeasured value in a measured library is what this section rules out. One caution worth recording: a calibration harness can be wrong in a way that looks like a result. Ours understated one probe roughly sevenfold, and nothing raised an error — the library stayed internally consistent and the bands looked plausible.

3.4 Keeping the Decoy Consistent

A decoy that convinces on the first request and contradicts itself on the third has announced that it is a trap. The hard part is consistency over an engagement: answering the same query identically twice, keeping a value stable when reached by a different route, returning what was written, and resolving references between objects. A fact notebook meets all four, sitting between the decoy’s generators and its responses, recording each value the first time it is needed and serving that value thereafter. The generator can be anything, since the notebook only requires that a value never change once produced.

Measuring this needs an adversary, because a decoy asked one question twice passes almost by accident. A fuzzer interrogates it for the same fact through different routes, orders and repetitions. With the notebook the contradiction rate over **286 adversarial probes is zero**; without it, **100%**. The same split holds against a local language model, so the guarantee belongs to the notebook rather than to whatever writes the content.

Self-consistency is the wrong estimand. Every probe above asks the decoy about the decoy. That is right for the notebook but not what an attacker tests. A diverted session remembers the *real* application: it read object ids before being moved and can read them again after, so a decoy can score zero against itself while contradicting everything the attacker already saw.

Adversarial re-testing found four tells there, each surfaced by attacking the fix for the one before: a re-read of the same path returned different values; an aggregate endpoint named a person differently from their profile page; an id that returned *not found* before the divert existed afterwards; and a dashboard claimed ownership of a record the attacker knew was someone else’s. All are reachable by an attacker who simply remembers, and none is visible to a within-decoy metric. So we report a second measurement: a harness reads records and profiles on the target, triggers a divert, re-reads the same ids, and counts every field that disagrees across the boundary. The proxy carries a session’s pre-divert observations forward, including the *absences* it confirmed, so already-seen state survives the move while anything never looked at stays fabricated. Over 25 diverted sessions and 4,600 compared fields the rate is **zero**, and the measurement is not vacuous: disabling the carry-forward reproduces the tells at **90.8%**. We stop short of claiming the class closed, since each tell was found only by attacking the last fix.

Table 2. The randomised holdout. Both groups reached the probing band under the same policy; only the probe differs.

group	n diverted divert rate		
baited (policy)	10,643	10,112	0.950
withheld (holdout)	1,237	1,089	0.880

4 Results

Section 3.2 makes a prediction that can fail: a priced probe should help where the passive classifier is genuinely uncertain, and nowhere else. A probe raising recall everywhere would indicate a weak meter rather than correct pricing, and one raising recall by diverting honest users would be worthless whatever the arithmetic said. So we ask, in order: does the probe *cause* more attackers to be caught, where does the gain live, and what does it cost the benign side?

Three arms differ only in the code path selected by one mode flag against a single frozen model: **B1**, a signature WAF; **B2**, the passive dual meter; **B4**, the full system. Each ran over **99 independent seeded traffic draws** of 120 attack and 80 benign sessions, giving 11,880 attack and 7,920 benign sessions per arm. Within a seed every arm sees byte-identical traffic, so each attack session forms a matched pair. Throughout, *diverted* means the policy decided to divert, counted identically in every arm, so recall is comparable by construction. The primary comparison was fixed before the runs.

4.1 The Causal Estimate

B2 against B4 compares two whole systems differing in more than the probe. What isolates it is a **randomised holdout inside the treated arm**: whenever the policy decides to bait, a pseudo-random draw over the session id withholds the probe from about one session in ten. Withheld sessions sit at the same belief, under the same policy, in the same band, and are simply passed instead of probed.

The effect is **+0.070**, bootstrap 95% CI [**+0.052**, **+0.088**], odds ratio 2.59, Fisher exact $p = 3.4 \times 10^{-19}$. Probing causes diversions that would not otherwise have happened, at the same belief state. A randomised design is only worth the name if the draw balanced, so we check: the largest share difference across the five subcategories is 1.2 percentage points, and a chi-square of the withheld mix against the treated gives 2.58 on four degrees of freedom, well inside 9.49.

4.2 Baselines

Of 11,880 matched attack sessions, 10,841 are concordant, **842 are caught by B4 alone and 197 by B2 alone**, giving McNemar $p = 1.9 \times 10^{-95}$; B4 leads in **99 of 99 seeds**, which rules out a lucky draw. The 197 going the other way are

Table 3. Attack recall and benign cost over 99 paired seeds. B2 and B4 intervals do not overlap.

arm	recall (Wilson 95% CI)	per-seed sd	benign diverted
B1 signature WAF	0.366 [0.358, 0.375]	0.020	0 / 7,920
B2 passive	0.889 [0.883, 0.894]	0.024	4 / 7,920
B4 full	0.943 [0.939, 0.947]	0.018	0 / 7,920

Table 4. OWASP ModSecurity CRS on identical traffic. Perfect recall is reachable only at a setting no operator can run.

	CRS paranoia	attack recall (95% CI)	benign sessions blocked
1 (default)	0.353	[0.305, 0.404]	0 / 240
2	0.544	[0.493, 0.595]	0 / 240
3	0.544	[0.493, 0.595]	0 / 240
4 (maximum)	1.000	[0.989, 1.000]	72 / 240 (30%)

not noise. They are *deferrals*: sessions whose belief landed between the cost-only boundary at 0.816 and the derived divert edge at 0.879, where B2 diverts at once and B4 buys information first. Some end without the probe ever being answered. That is the visible price of the third action.

The two zeros in the benign column invite suspicion, so it is worth saying what produced them. B1’s is unremarkable: its patterns need SQL syntax context that honest traffic does not supply. B4’s is the interesting one, because it is not merely as safe as the passive arm but safer, by the mechanism Section 3.2 predicts. All four benign sessions B2 wrongly diverted landed in the probing band under B4. Each was probed rather than diverted, none bit, and the *absence* of a bite held the belief below 0.879 where B2’s boundary of 0.816 had already committed. Raising the divert threshold is not a safety concession bolted on afterwards; it is what the pricing implies, and here it recovered every false positive the passive detector produced.

B1 is a fair reference rather than a straw man, but a reader is entitled to distrust a baseline its authors wrote. So we replayed the same traffic through **OWASP ModSecurity CRS** at every paranoia level it defines.

At its default setting the real ruleset scores 0.353 against B1’s 0.366 with heavily overlapping intervals, so B1 is not a weakened stand-in. The ceiling is not a tuning question either: CRS reaches perfect recall only by blocking **thirty per cent of legitimate sessions**, and across every setting that leaves benign traffic alone it tops out near 0.54, against 0.943 at zero benign diversions here. The comparison is generous to CRS in one respect: it is judged on blocking any request of a session, while our arms are judged on diverting the session, and blocking is easier.

4.3 Where the Probe Acts

Splitting the matched pairs by subcategory is the sharpest test of the theory, which says the gain must be *concentrated*. It is. The entire net gain sits in UI-based scattered object access: recall $0.540 \rightarrow 0.823$, a gain of **+0.282** over 1,980 pairs at a bite rate of 0.620, with a paired McNemar on that subcategory alone of $b = 639$ against $c = 80$ ($p < 10^{-4}$). Elsewhere the probe is neutral: +0.022 on obfuscated SQLi, and zero on stealth SQLi, API-side object access and credential spray. That is the one category a signature cannot see and the one where the passive meter is undecided, exactly where Section 3.2 says information is worth buying. Stealth SQLi bites half the time and does not move at all: the information was bought and proved unnecessary.

One category cannot reach the probe at all, and it is half of what B4 still misses. Obfuscated SQLi bites exactly zero times despite nine in ten of its sessions being shown a probe, and accounts for 405 of B4’s 799 misses. The cause lies in the attacker model, not the defence: those profiles fire payloads and never read what comes back, so a response-side probe cannot reach them. Ablations, an adaptive-adversary sweep, a transfer check against a second application, and runs against sqlmap, ghauri, OWASP ZAP and Wapiti are reported in the artefact.

5 Discussion

The results support the mechanism rather than a headline number. A probe lifting recall everywhere would suggest a weak meter; instead the gain of +0.282 is confined to the one subcategory where the passive detector is undecided and is roughly zero in the four where it is not. That is the pricing argument doing what it predicts: information is worth buying exactly where the decision is in doubt. The holdout separates that effect from every other difference between two systems, and the raised divert edge explains why the safest arm is also the most accurate.

Where the approach does not win. Deriving the band edges did not beat setting them by hand on expected cost, and we report the measured reason rather than the claim. The belief those edges apply to takes essentially two distinct values on this system, so four decimal places of derived precision are not doing the work they appear to, and every configuration beating the derived pair on cost does so by diverting benign users. Among configurations that divert none, the derived edges are the best available. That is narrower than we set out to claim and more useful: it says what the derivation buys, a placement clearing the benign belief distribution by construction, rather than asserting a superiority the data does not support. A related gap is structural. The rule is derived for a single decision but deployed as a first-crossing test over a session, and here that mismatch happens to cancel against the meter’s miscalibration. A rule that is right for compensating reasons is a different object from a rule that is right.

Limitations. Four, in order of severity. *All traffic is synthetic*, so every rate describes this distribution and would need re-measuring on a real one; the derivation and the holdout design do not depend on the traffic being real, but the magnitudes do. *A single tuned application*: placing the frozen model in front of a structurally different second one shows the app-agnostic features fire correctly, but the app-specific probes would need re-pointing, and a full evaluation with a matched decoy there remains undone. *The deception is not validated by human participants*; whether a human attacker *feels* something is off is unmeasured, and it is the single most valuable thing left to measure. β_a *is a property of an attacker model we chose*. We narrow this by driving autonomous language-model agents told nothing about the probes, whose bite rate rises with capability and whose largest lands inside the range we assumed. An agent is still not a person.

6 Conclusion

Passive web defences force a choice between acting early on weak evidence and acting late on strong evidence. That choice is avoidable: a defender can *manufacture* evidence by planting an invisible, inert probe, and when to do so follows from the expected value of the information it buys. Priced this way, probing is the cost-optimal action over a band that does not exist under cost accounting alone, so it cannot be a tuned threshold. The evaluation supports the mechanism rather than a number: the gain appears only where the classifier is genuinely unsure, a randomised holdout attributes it causally to the probe, and no legitimate session was diverted. What remains is real traffic, and a real attacker.

References

1. Amouei, M., Rezvani, M., Fateh, M.: Rat: Reinforcement-learning-driven and adaptive testing for vulnerability discovery in web application firewalls. *IEEE Transactions on Dependable and Secure Computing* **19**(5), 3371–3386 (Sep 2022)
2. Arp, D., Quiring, E., Pendlebury, F., Warnecke, A., Pierazzi, F., Wressnegger, C., Cavallaro, L., Rieck, K.: Dos and don'ts of machine learning in computer security. In: *Proceedings of the 31st USENIX Security Symposium*. pp. 3971–3988. Boston, MA, USA (2022)
3. Axelsson, S.: The base-rate fallacy and the difficulty of intrusion detection. *ACM Trans. Inf. Syst. Secur.* **3**(3), 186–205 (Aug 2000)
4. Bridges, R.A., Mitchell, T.R., Muñoz, M., Henriksson, T.: Sok: Honeypots & llms, more than the sum of their parts? In: *2026 IEEE 11th European Symposium on Security and Privacy (EuroS&P)*. pp. 910–928 (July 2026)
5. Elkan, C.: The foundations of cost-sensitive learning. In: *Proceedings of the 17th International Joint Conference on Artificial Intelligence - Volume 2*. p. 973–978. IJCAI'01, Morgan Kaufmann Publishers Inc., San Francisco, CA, USA (2001)
6. Ferguson-Walter, K.J., Major, M.M., Johnson, C.K., Muhleman, D.H.: Examining the efficacy of decoy-based and psychological cyber deception. In: *Proceedings of the 30th USENIX Security Symposium* (2021)
7. Howard, R.A.: Information value theory. *IEEE Transactions on Systems Science and Cybernetics* **2**(1), 22–26 (Aug 1966)

8. Iliou, C., Kostoulas, T., Tsikrika, T., Katos, V., Vrochidis, S., Kompatsiaris, Y.: Towards a framework for detecting advanced web bots. In: Proceedings of the 14th International Conference on Availability, Reliability and Security. ARES '19, Association for Computing Machinery, New York, NY, USA (2019)
9. Juels, A., Rivest, R.L.: Honeywords: making password-cracking detectable. In: Proceedings of the 2013 ACM SIGSAC Conference on Computer & Communications Security. p. 145–160. CCS '13, Association for Computing Machinery, New York, NY, USA (2013)
10. Kahlhofer, M., Golinelli, M., Rass, S.: Koney: A cyber deception orchestration framework for kubernetes. In: 2025 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW). pp. 690–702 (June 2025)
11. Kahlhofer, M., Rass, S.: Application layer cyber deception without developer interaction. In: 2024 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW). pp. 416–429 (July 2024)
12. Kruegel, C., Vigna, G.: Anomaly detection of web-based attacks. In: Proceedings of the 10th ACM Conference on Computer and Communications Security (CCS '03). pp. 251–261 (2003)
13. Pawlick, J., Colbert, E., Zhu, Q.: A game-theoretic taxonomy and survey of defensive deception for cybersecurity and privacy. *ACM Comput. Surv.* **52**(4) (Aug 2019)
14. Pawlick, J., Colbert, E., Zhu, Q.: Modeling and analysis of leaky deception using signaling games with evidence. *IEEE Transactions on Information Forensics and Security* **14**(7), 1871–1886 (July 2019)
15. Provos, N.: A virtual honeypot framework. In: Proceedings of the 13th USENIX Security Symposium. pp. 1–14. San Diego, CA, USA (2004)
16. Sladić, M., Valeros, V., Catania, C., Garcia, S.: Llm in the shell: Generative honeypots. In: 2024 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW). pp. 430–435 (July 2024)
17. Sommer, R., Paxson, V.: Outside the closed world: On using machine learning for network intrusion detection. In: 2010 IEEE Symposium on Security and Privacy. pp. 305–316 (May 2010)
18. Vero, M., Kaczmarczyk, F., Petrov, I., Shumailov, I., Hayes, J., Heinen, N., Fan, T., Invernizzi, L., Vechev, M.: Honeyval: A comprehensive evaluation framework for llm-powered http honeypots (2026)
19. Vetterl, A., Clayton, R.: Bitter harvest: systematically fingerprinting low- and medium-interaction honeypots at internet scale. In: Proceedings of the 12th USENIX Conference on Offensive Technologies. p. 9. WOOT'18, USENIX Association, USA (2018)
20. Yuill, J., Zappe, M., Denning, D., Feer, F.: Honeyfiles: deceptive files for intrusion detection. In: Proceedings from the Fifth Annual IEEE SMC Information Assurance Workshop, 2004. pp. 116–122 (June 2004)